

Industrial Security (Bachelor)

Exercise Sheet – Section 05

Threat Landscape

Goal. These exercises ask you to reason about real ICS incidents – Stuxnet, Ukraine 2015/2016, TRITON, NotPetya, Colonial, PIPEDREAM, CyberAv3ngers and Volt Typhoon – using the case-study material from the slides and the cited CISA / vendor / academic sources. Most questions are short scenarios; the last one is an open mini-essay. Answers should be concise (3–10 sentences each unless stated otherwise) and grounded in the published sources, not speculation.

Exercise 5.1 – Stuxnet on the ATT&CK for ICS Matrix

Map the Stuxnet kill-chain to the MITRE ATT&CK for ICS matrix. For each of the following six phases of the attack, name (a) the ATT&CK *tactic column* it sits in, and (b) one concrete *technique ID* (T0xxx) you would assign:

1. Crossing the air gap on a contractor's USB stick.
2. Spreading inside the engineering LAN using a Windows print-spooler zero-day.
3. Loading a kernel driver signed with a stolen Realtek certificate.
4. Injecting malicious ladder logic into the S7-315 PLC via the Step7 DLL.
5. Driving the Vacon / Fararo Paya VFDs outside their operating envelope.
6. Replaying 21 seconds of recorded normal telemetry to the HMI during the attack.

Present your answer as a three-column table (*Phase, Tactic, Technique ID*). Cite the ATT&CK for ICS matrix as your reference.

Exercise 5.2 – Ukraine 2015 vs. Ukraine 2016

Both the December 2015 BlackEnergy attack and the December 2016 Industroyer / CrashOverride attack blacked out parts of Ukraine, but they were qualitatively different operations. Compare them in a short table covering these four axes:

1. **Target tier** – distribution oblenergos vs. transmission substation.
2. **Human-in-the-loop** – did a human click breakers, or did malware?
3. **Protocol awareness** – generic remote control vs. purpose-built modules (IEC 60870-5-101/104, IEC 61850 MMS, OPC DA).
4. **Recovery effort / time** – outage hours and what restoration required.

Conclude with one sentence on what the 2015 → 2016 transition implies about attacker capability.

Exercise 5.3 – TRITON: a Partial Defender Win

TRITON / TRISIS (Saudi petrochemical plant, August 2017) targeted a Schneider Triconex safety instrumented system (SIS). In production, the SIS tripped the plant to a safe state and the campaign was exposed.

1. In 2–3 sentences, describe what the attacker presumably *wanted* the SIS to do, and how this was meant to combine with a separate attack on the BPCS.
2. Explain in 2–3 sentences why the actual outcome (safe-state trip + discovery) was a partial defender win, and why it was nonetheless deeply unsettling.
3. Name one technical reason TRITON-class implants are hard to detect on Triconex controllers (where the malicious logic lived, what protocol it spoke).

Exercise 5.4 – Volt Typhoon and Living off the Land

CISA advisory *AA24-038A* (7 Feb 2024) attributes a long-running campaign against US critical infrastructure to Volt Typhoon, who rely almost exclusively on *living-off-the-land binaries* (LOLBins) instead of custom malware.

1. List **four** LOLBins or built-in Windows tools that the slides and AA24-038A associate with this actor (e.g. `wmic`, `ntdsutil`, PowerShell, ...).
2. For each, explain in one sentence what an admin would normally use it for.
3. Explain in 3–5 sentences why a defender’s signature-based endpoint product (AV / EDR signatures keyed on file hashes or known IOCs) is structurally unable to flag this kind of activity, and what class of detection *can*.

Exercise 5.5 – PIPEDREAM: Caught Before Impact

PIPEDREAM / INCONTROLLER / CHERNOVITE (CISA *AA22-103A*, 13 Apr 2022) is the first modular ICS attack framework that was discovered *before* it caused any victim impact, thanks to early reporting by a partner.

1. Why does “caught before deployment” matter *geopolitically*, compared to a post-incident discovery like Stuxnet or Industroyer? (2–3 sentences.)
2. What does PIPEDREAM’s design – pre-built modules for Schneider M340/M580, Omron NX/NJ, OPC UA and CODESYS, with scanning, parameter changes, logic upload and denial of control – tell you about the maturity of state-sponsored ICS tooling in 2022? (2–3 sentences.)
3. Name one defensive action a Schneider or Omron asset owner should have taken *immediately* on reading AA22-103A.

Exercise 5.6 – Colonial Pipeline: Decoupling IT and OT

The Colonial Pipeline incident (7 May 2021) is widely cited as an “IT incident that took OT down”. The DarkSide affiliate compromised the corporate IT environment; OT control was never directly attacked, yet Colonial halted the 8 850 km pipeline for five days.

1. In your own words, describe the dependency chain that turned an IT ransomware event into a fuel-supply crisis on the US east coast. Be specific about *which* IT function the operator could not do without.
2. Propose **two** architectural or organisational changes that would have allowed OT to keep flowing product even while corporate IT was encrypted. For each, name one cost or trade-off (capex, complexity, regulatory, ...) that explains why it was not in place.

Exercise 5.7 – Reading a CISA Advisory: AA23-335A

Read CISA advisory *AA23-335A* (“IRGC-Affiliated Cyber Actors Exploiting PLCs in Multiple Sectors, Including U.S. Water and Wastewater Systems Facilities”, 1 Dec 2023). Answer:

1. Which specific PLC product family did CyberAv3ngers target, and on which TCP port does its engineering protocol listen?
2. Which default password did the attackers use, and what was the highest-profile US victim cited in the advisory?
3. What is CISA’s *first* listed mitigation recommendation? (Quote or paraphrase the action verb.)
4. In one sentence: which one of the eight initial-access vectors on the slides was the decisive one for this campaign?

Exercise 5.8 – Pyramid of Pain

The “Pyramid of Pain” (Bianco, 2013) ranks indicators of compromise by how painful they are for the attacker to change. Rank the following five IOC types from **easiest** (attacker swaps in minutes) to **hardest** (forces the attacker to rebuild their tradecraft), and justify each placement in one sentence:

- MD5 hash of a payload binary.
- C2 IP address.
- Registry key used for autorun persistence.
- C2 domain name.
- MITRE ATT&CK technique (e.g. T0855 “Unauthorized Command Message”).

Conclude with one sentence on what this implies for a SOC that detects *only* on hashes.

Exercise 5.9 – Insider Threat: First 24 Hours

A contract control-systems engineer at a mid-size chemical plant hands in their notice on a Friday afternoon. On the same day, SIEM logs show that their account downloaded the full DCS project file (HMI graphics, controller config, tag database, alarm setpoints) from the engineering server to a personal laptop over the corporate VPN, outside their usual working hours.

Walk through what the security team should do in the **first 24 hours**. Cover, in order:

1. Containment actions on accounts, VPN sessions and physical access.
2. Evidence preservation – which artefacts must be captured before they age out?
3. Who to notify inside the organisation (and roughly when), and which external parties (legal, HR, law enforcement, sectoral CERT) come into scope and on what trigger.
4. One thing the team must *not* do that would be tempting (think evidentiary integrity, employment law, or alerting the suspect).

Exercise 5.10 – Open Research: A Decision You Would Reverse

Choose **one** of the case-study incidents covered in this section – Stuxnet, Ukraine 2015, Ukraine 2016 (Industroyer), TRITON, NotPetya, Colonial Pipeline, PIPEDREAM, CyberAv3ngers, or Volt Typhoon – and write a one-page (about 400–600 word) analysis of *one* decision the defenders (asset owner, integrator, vendor, or regulator) made before or during the incident that, with hindsight, you would do differently.

Your write-up should: (i) name the decision and the actor who made it, citing at least one primary source (CISA advisory, ICS-CERT alert, vendor PSIRT, peer-reviewed paper, or named journalism / book); (ii) explain the operational or commercial reasoning that made the decision defensible at the time; (iii) describe the alternative you would have chosen and the cost it would have carried; (iv) assess whether your alternative would have changed the outcome materially, or only at the margin.